RxHub · Parent-App Integration Guide

Final handover for the team building the Leadway Provider dashboard's RxHub tile. Covers the single API call your backend makes, how the iframe is embedded, and the security properties you get by default.

What you're integrating

RxHub is a prescription submission and fulfilment-tracking portal. Leadway providers open it inside an iframe on your provider dashboard. They should arrive already signed in — no second login screen.

Architecture summary

```
Your dashboard              RxHub backend                RxHub frontend (iframe)
■■■■■■■■■■■■■■■■            ■■■■■■■■■■■■■■■■                ■■■■■■■■■■■■■■■■■■■■■■■■■■■■
Provider clicks "Open RxHub"
        ■
        ■  POST /api/v1/auth/embed-login          (server-side, NOT browser)
        ■    Header:  X-Embed-Secret: <shared>
        ■    Body:    { email, password }
        ■■■■■■■■■■■■■■■■■■■
```

Successful response (HTTP 200)

```
{
  "portal_url":        "https://<rxhub-frontend-url>/?ticket=8wZ-yR2Qn0…XQk",
  "ticket_expires_in": 60
}
```

Error responses

HTTP	Reason	What to do
401	Bad credentials or bad embed secret	Show "could not sign in" to the provider
403	Admin account attempted embed-login	Admins sign in directly — tell them to use the direct URL
503	Embed login disabled on backend (env var not set)	Contact the RxHub team
429	Rate limited (30 requests / minute / IP)	Retry after 60 seconds

Step 2 — Embed the returned URL in an iframe

As soon as you receive the `portal_url`, embed it directly. Redirect the user to the page that holds the iframe immediately — the ticket is only valid for **60 seconds** from issue.

```
<iframe
  src="{portal_url}"
  width="100%"
  height="800"
  style="border: 0;"
  allow="clipboard-write; web-share"
  title="Leadway RxHub">
</iframe>
```

Step 3 — That's it

Once the iframe loads, RxHub reads the ticket, exchanges it (one-time), stores the JWT in sessionStorage, scrubs the URL, and renders the prescription form. The provider's session lasts **8 hours** from redemption. They can navigate freely inside the iframe — no further calls from your side are needed.

Security properties you get for free

Threat	Mitigation
JWT leaked via browser history / referrer / logs	JWT never appears in a URL — only the opaque ticket does
Ticket replay	Single-use, atomic pop on redeem, 60-second TTL
Ticket brute-force	256-bit entropy (43 URL-safe characters)
Your dashboard impersonated	X-Embed-Secret validated via constant-time HMAC comparison
Admin account hijack via embed path	Admin accounts explicitly rejected (HTTP 403)
Direct provider sign-in at the portal URL	Portal blocks all non-ticket entry in embed-only mode

What we send you separately (secure channel)

Value	Example / purpose
<rxhub-api-url>	e.g. https://rxhub-api.leadwayhealth.com
<rxhub-frontend-url>	e.g. https://rxhub.leadwayhealth.com
EMBED_SHARED_SECRET	64-character random string. Keep in your backend vault. Never commit, never send to b

If the shared secret ever leaks, contact the RxHub team — we will rotate it and send you the new value.

Testing / local dev checklist

1. Make a curl call first (no iframe yet):

```
curl -X POST https://<rxhub-api-url>/api/v1/auth/embed-login \
  -H "X-Embed-Secret: <secret>" \
  -H "Content-Type: application/json" \
  -d '{"email":"<valid-email>","password":"<valid-password>"}'
```

You should get back a `portal_url` with a ticket appended.

2. Open that URL directly in a browser **within 60 seconds**. The portal should load straight to the prescription form — no login screen.

3. Now wrap it in your iframe and confirm the provider sees the form.

4. Sign out. Confirm the portal blocks direct access ("open from your provider dashboard" screen appears).

Admin access (stays with the project owner, not the parent app)

Admin access is unchanged and does NOT go through the parent app. The project owner signs in directly:

```
https://<rxhub-frontend-url>/?admin=1
```

The `?admin=1` query parameter reveals the standard email/password form. Log in with the `ADMIN_BOOTSTRAP_EMAIL` / `ADMIN_BOOTSTRAP_PASSWORD` set in the backend configuration. Once signed in, the admin sees:

- Every prescription across all providers, filterable by WellaHealth fulfilment status (Pending / Dispensed / Cancelled / etc.).
- Both the WellaHealth tracking code (e.g. WTR-5864CE2DA0) AND the 8-digit pickup OTP (e.g. 70212673) for every request, with one-click copy buttons.
- Instant CSV export of any filtered view — opens directly in Excel.
- Per-request detail drawer with full timeline, medications, attachments, and a live "refresh from WellaHealth" button.
- Summary dashboard broken down by channel, classification, fulfilment status, and enrollee state.

Nobody else has access to this URL unless they hold the admin credentials. Keep them safe.

Frequently asked questions

Can I test from a plain browser without your embed?

Yes — use `?admin=1` and sign in with the admin credentials supplied separately.

Does the iframe need CORS headers from my side?

No. CORS is on the API, not the iframe. Just embed the URL.

What if my provider dashboard uses SSO (SAML/OAuth)?

Same integration. Your backend collects or issues the provider's email + password and forwards them to `/auth/embed-login`.

What if a provider has the RxHub URL directly?

They see the "open from your provider dashboard" block screen. No login form is shown.

Can I link out instead of iframe?

Yes — the same `portal_url` works as an anchor target. Iframe is just a UX choice.

How often do ticket requests hit the rate limit?

The limit is 30 per minute per IP. A normal dashboard never gets close. If you do, investigate whether the server is calling embed-login in a loop.

Contact

If anything returns a 401 that shouldn't, or you need the shared secret rotated, reach out to the project owner. Include the HTTP status code and the response body — that's enough to diagnose most issues.